



Bot System Audit — Sample Report

Independent review of multi-department support-automation bots · deliverable format

Prepared by [Waseem Iftikhar](#)
[github.com/waseem253/bot-system-audit](#)

SAMPLE · ANONYMISED · NOT A REAL CLIENT

Executive summary

This is the exact format a client receives. The reviewed system runs department bots (sales, support, billing, WhatsApp) over a shared automation layer. It works day-to-day, but **three issues make it unsafe to scale further automation today**: a lossy sales→support handoff, an inflated resolution metric, and an unsanitised tool-call path. None are visible from inside the team because each sits between two bots that are individually "fine". Fixing the four quick wins removes the most material risk inside the first week.

Verdict: Functional, not yet scale-ready. Address F-01, F-02, F-04 before adding automation; the rest is a sequenced roadmap.

Scorecard (0–5, 5 = production-excellent)



Findings register

ID	DIMENSION	SEV	FINDING & IMPACT	FIX	EFFORT
F-01	Workflow	CRIT	Sales→Support handoff drops lead_id on timeout, no retry. ~6% escalated leads unattributable; silent revenue leakage.	Idempotent handoff, persisted correlation ID, dead-letter retry	2d
F-02	Reporting	HIGH	"Resolved" counted on bot reply, not user confirmation. Resolution rate overstated ~18%; KPI decisions skewed.	Redefine to confirmed-resolution event; backfill 90d	1.5d
F-03	Lead mgmt	HIGH	No dedup across WhatsApp and web bots. Leads double-counted; sales double-contacts.	Normalise on phone+email hash at ingest; merge rule	1d
F-04	AI safety	HIGH	User text echoed into a tool call unsanitised. Prompt-injection can trigger internal actions.	Strict tool-arg schema + allowlist; no free-text into actions	1d
F-05	Conversation	MED	11% fallback on billing bot; 3 dead-end intents. Avoidable escalations.	Add missing intents; fallback → clarifying question	1d
F-06	Reliability	MED	No alerting on webhook 5xx; failures found via complaints. MTTD in hours.	Error-rate alert + per-bot synthetic heartbeat	0.5d
F-07	Scalability	MED	All bots share one API key, no rate isolation. One noisy bot throttles all.	Per-bot keys + budget caps	0.5d
F-08	Security	LOW	Inbound webhooks unauthenticated (URL obscurity only). Spoofed events possible.	Signature verification on every inbound webhook	0.5d

Prioritised remediation roadmap

- **Week 1 — quick wins (≤ 1 d each):** F-04, F-06, F-07, F-08 — biggest risk reduction for least effort.
- **Week 2 — accuracy & integrity:** F-01 (handoff), F-02 (metric redefinition + backfill).
- **Week 3 — data quality & UX:** F-03 (dedup), F-05 (intent coverage).
- **Then scale:** re-audit the scorecard; only add new automation once Workflow, Reporting and AI-safety reach $\geq 4/5$.